Vulnerability management - OrdinCore

Owner: engineering lead. Review: annually.

Timescales

- Critical and high-severity security patches (OS, runtime, dependencies): applied within 14 days of a fix being available - sooner for actively-exploited issues.
- Medium/low: at the next routine maintenance window.
- End-of-life (EOL) software: must not run in production. Migration is planned and tracked ahead of the EOL date; any component found at/after EOL is treated as a priority action.

How vulnerabilities are identified

- Dependency advisories: CI fails the build on high/critical advisories; automated weekly update PRs are raised for backend, frontend, mobile and landing-page dependencies.
- OS/runtime: tracked against EOL dates and reviewed quarterly.
- Security testing: an internal vulnerability assessment and penetration test has been carried out against the codebase and the live production system; findings were triaged and remediated.

How patches are applied

- Dependency updates go through an automated PR -> CI (build/test/migrate/audit) -> review -> merge pipeline, then deploy via the standard deployment process.
- OS/runtime/database upgrades are planned changes with a documented rollback plan and a tested backup taken first.

Communicating to customers

- Security-relevant incidents follow a defined notification process: affected customers (and, where a breach meets the high-risk threshold, affected individuals) are notified without undue delay, with an initial notification covering what happened, when it was detected, and who may be affected, followed by a closure notification covering root cause and remediation.
- Planned maintenance or upgrades that could affect service availability are communicated to customer contacts in advance.